Fix: npm audit warnings

Type: Fix

Size: light - `npm audit fix` moves packages to their patched releases inside the ranges `package.json` already allows, no code change; proved by the builds, the suites and a walk through the dashboard.

Status: verified

Branch: fix/npm-audit-warnings

The problem

After the Next.js fix (2026-10-25), `npm audit` still lists 16 warnings, 7 high and 9 moderate. Three reach the live app: `zod` 4.6.5 (high: memory exhaustion validating oversized constrained collections; the API validates every request with it), `hono` 4.13.8 (moderate: `serveStatic` decodes the path twice; the API does not use `serveStatic`) and `fast-uri` (moderate, inside `ajv` under `@hookform/resolvers` in the dashboard). The rest are laptop tools only: the `shadcn` CLI and what it pulls in (`@modelcontextprotocol/sdk`, `body-parser`, `undici` 7, `ip-address`), the test runner (`vitest`, `@vitest/mocker`, `vite`, `jsdom`'s `undici` 8) and `source-map-js` in the build. Frank's yes, 2026-10-26.

- `package-lock.json`

The fix

Run `npm audit fix` without `--force`: every warning but one has a patched release inside the caret range already in `package.json`, so only the lockfile moves. No new package, no major version.

Left on purpose: `drizzle-kit` and the old `esbuild` inside `@esbuild-kit` (one moderate warning chain). npm's only offer is to move `drizzle-kit` from 0.31 back to 0.18, an old release; the advisory is about esbuild's dev server reading responses for any website, and drizzle-kit never runs that server.

It must not break: the API and its validation, sign-in, the dashboard's pages, the customer's booking page, the booking window's build, and the test runs.

Build steps

- [x] 1. **npm audit fix. Done when:** `npm audit` lists only the drizzle-kit chain; every suite (shared, backend, booking component), both builds, the booking component build, lint and the format check pass; and on http://localhost:3400 sign-in, Leads, the Calendar, Settings (People and Services, one Save each) and a customer booking page at `/b/<token>` load with no console errors.

Verify

Open app.booking-crm.com after the deploy: sign in, open Leads, the Calendar and Settings, and book once from a booking page.

Implementation walkthrough

One step, as the spec planned (light), and one review round that passed with two P3 notes. Found after the Next.js fix (2026-10-25): `npm audit` still listed 16 warnings, 7 high and 9 moderate.

package-lock.json

`npm audit fix`, without `--force`, moved only the lockfile; no `package.json` changed. What the live app runs: `zod` 4.6.5 to 4.6.7 (the reviewer diffed it: the one runtime change is the advisory's fix, an array, map or set over its max size now fails before any element is parsed), `hono` 4.13.8 to 4.13.14 (the API never uses `serveStatic`), `fast-uri` 3.1.8 to 3.1.9 under the dashboard's form helper. Laptop tools: `shadcn` 4.21.0 to 4.22.1 with the MCP SDK, express, `body-parser`, `undici` 7 and `ip-address` under it; `vitest` 5.0.2 to 5.0.5, `vite` 8.3.1 to 8.3.5 and `jsdom`'s `undici` 8; `source-map-js` 1.2.2; `drizzle-kit` 0.31.11 (a patch); browser data. shadcn's nested old `zod` 3.25.76 is gone.

Not as the spec put it (F-517): "no new package, no major version" holds for direct dependencies only. Inside the shadcn CLI chain the lockfile adds `@shadcn/registry` and `type-fest`, and `content-disposition` moves 1.1 to 2.0.1. shadcn is in the frontend's `dependencies`, so these install on Vercel too, though the dashboard never runs that CLI. `shadcn/tailwind.css`, which `globals.css` imports, changed only a `shimmer` rule the dashboard does not use.

what is left on purpose

`npm audit` shows 4 moderate entries, one chain: `drizzle-kit` and the old `esbuild` inside `@esbuild-kit`. npm's only fix moves drizzle-kit from 0.31 back to 0.18.1; the advisory is about esbuild's dev server, which drizzle-kit, a dev dependency, never runs.

a flaky test

The first backend run failed `skills-carry-over` once; it passed alone and in every full run after. The reviewer found why (F-516): the test replays migration 0033's insert over every business in the database, so a parallel test file deleting its own business mid-run trips a foreign key. It predates this fix.

the build log

The Log-entries count of the last five log updates had landed on feature 8a's drawer instead of 12k's; both counts were set from their drawers (8a 11, 12k 17).

Findings

None resolved here. The review raised F-516 and F-517, both P3 and open; they stay in the ledger.

Independent review

Status: passed **Target commit:** 2a42e928c2aabad1fea0d3e3c2395409f445779a **Base commit:** 69309af39eba7ba9f248dccd4c2b5ac83ef82b55 **Base ref:** main **Spec hash:** 6d002f4ed3319e3a7a15d00e260918c6ad3611bea3f69cc6f42faa6e9f37b7e7 **Prepared by:** claude **Builder model:** claude-opus-5-5 **Requested reviewer:** claude **Requested model:** claude-opus-5-5 **Requested execution:** automatic **Requested at:** 2026-10-26T04:35:57Z **Workflow:** regular **Check required:** no **Reviewer adapter:** claude **Reviewer model:** claude-opus-5-5 **Reviewer context:** fresh subagent **Actual execution:** automatic **Reviewed at:** 2026-10-26T04:44:37Z **Scope:** current **Lenses:** quality, security, performance, tests **Verdict:** passed **Check result:** not-required

Commands

- `git rev-parse HEAD`, `git merge-base HEAD main`, `sha256sum blueprint/context/current-feature.md`, `git status --porcelain --untracked-files=all`: pass (HEAD = target, merge base = base, spec hash matches, only review.md differs)
- `npm run test --workspace=@scheduleads-app/shared`: pass (32 files, 214 tests)
- `npm run test --workspace=backend`: fail on the first run (1 of 1098, `skills-carry-over.test.ts`, foreign key race, F-516), pass alone and pass on the full rerun (95 files, 1098 tests)
- `npm run test --workspace=@frankdmosquera/booking-component`: pass (18 files, 98 tests)
- `npm run build --workspace=backend`: pass
- `npm run build --workspace=frontend`: pass (includes `build:types` and the booking component build)
- `npm run lint --workspace=frontend`: pass
- `npm run format:check`: pass
- `npm audit`: 4 moderate, all one chain (`esbuild` 0.18.20 under `@esbuild-kit/core-utils` and `@esbuild-kit/esm-loader` under `drizzle-kit` 0.31.11), exactly what the spec leaves on purpose
- `npm ls --all`: exit 0, no invalid or missing packages

Evidence

- Delta is two files: `package-lock.json` and `blueprint/context/current-feature.md`. No `package.json` changed anywhere (checked with `git diff --name-only` over `*package.json`).
- Lockfile compared package by package between base and target: 50 version moves, 5 entries added, 2 removed, 1 flag change. Live API and dashboard moves: `zod` 4.6.5 to 4.6.7, `hono` 4.13.8 to 4.13.14, `fast-uri` 3.1.8 to 3.1.9 (under `ajv`, dashboard forms). The rest are laptop or build tools:

`shadcn` 4.21.0 to 4.22.1 with `@modelcontextprotocol/sdk` 1.30.0 to 1.32.2, `express` 5.2.1 to 5.3.0, `body-parser` 2.3.0 to 2.4.0, `undici` 7.29.1 to 7.30.1, `ip-address` 10.7.2 to 10.7.5; `vitest` / `@vitest/*` 5.0.2 to 5.0.5, `vite` 8.3.1 to 8.3.5, `rolldown` 1.2.11 to 1.2.15, jsdom's `undici` 8.11.2 to 8.12.3, `source-map-js` 1.2.1 to 1.2.2, `drizzle-kit` 0.31.10 to 0.31.11; browserslist data refreshes.

- Added and removed entries all trace to the updated tools (F-517): `@shadcn/registry` 0.2.0, `type-fest` 4.41.0 and shadcn's private `zod` 3 gone (shadcn now on zod `^4.2.0`); `content-disposition` 1.1.0 to 2.0.1 because `express` 5.3.0 asks `^2.0.1`; `why-is-node-running` 3.2.2 to 3.2.1 because `vitest` 5.0.5 pins `3.2.1`.
- Installed `node_modules` match the target lockfile for every package checked (zod, hono, fast-uri, shadcn, express, vite, vitest, drizzle-kit, undici both copies).
- `zod` source compared against the 4.6.5 tarball from the local npm cache (offline): the only runtime change is a size gate that fails an array, map or set over its `.max()` / `.length()` / `.size()` cap before parsing any element (`capSize` in `v4/core/schemas.ts`, `generateSizeGate` in `v4/core/compile.ts`), which is the advisory's fix; plus a type-only change to `$ZodRecordInternals`. The only visible difference for the API is that an oversized array now reports just its size issue.
- `hono` 4.13.14 is rebuilt with a different bundler (every `dist` file differs by comments and regions), so a source diff is not readable; covered by the 1098 backend route tests and the frontend's typed client build. The API does not use `serveStatic` (no match in `backend`).
- `shadcn/tailwind.css`, which `frontend/app/globals.css` imports, changed only in a reduced-motion rule for the `shimmer` utility and a comment; the dashboard uses no `shimmer`.
- Left-on-purpose decision holds: `drizzle-kit` is a devDependency of `packages/shared` only, its `@esbuild-kit` loader uses esbuild's transform, never its dev server (the advisory's subject), and npm's only fix is a downgrade to `drizzle-kit` 0.18.1.
- The running dev frontend (port 3400) started after the lockfile install, so the builder's walkthrough ran on the new packages. Both dev servers answered 200 after this review's builds; nothing on 3000/3001 was touched.
- Working tree after all checks: only `blueprint/context/review.md` and `blueprint/context/findings.md` differ.

Findings

- F-516 [P3] open: the skills carry-over test replays migration 0033 over every business, so a parallel test file's delete can fail it (pre-existing, not caused by this delta)
- F-517 [P3] open: the spec's "no new package, no major version" holds for direct dependencies only; the shadcn and express updates add three packages and move content-disposition to 2.x

Remaining risk

- The browser walkthrough in the spec's Done when (sign-in, Leads, Calendar, Settings saves, a `/b/<token>` page) was not repeated by the reviewer; Check was not required.
- The `hono` 4.13.8 to 4.13.14 runtime changes were not read line by line (bundler change makes the diff unreadable); relied on the backend suite and the typed client build.
- `npm audit` is a network query of the registry's advisories at review time; the dashboard step activity (`run.json`) was not written by this reviewer, as instructed to write only the two review files.
- The production deploy check in the spec's Verify section (app.booking-crm.com after deploy) is outside this review.